

A01 Złamana kontrola dostępu

Kontrola dostępu egzekwuje zasad , które uniemożliwiają użytkownikom działanie poza przyznanymi uprawnieniami.

Awarie - nieautoryzowane ujawnienie informacji, modyfikacji lub zniszczenia wszystkich danych.

Typowe Luki :

- Naruszenie zasady najmniejszych uprawnień
- Omijanie kontroli dostępu poprzez modyfikację adresu URL (manipulacja parametrami, wymuszanie przeglądania)
- Zezwalanie na przeglądanie lub edytowanie konta innej osoby poprzez podanie jej unikalnego identyfikatora.
- Dostępne API , w którym brakuje kontroli dostępu (polecenia POST , PUT i DELETE.)
- Podniesienie uprawnień użytkownika.

A02 Błędna konfiguracja zabezpieczeń

Nieprawidłowa Konfiguracja zabezpieczeń ma miejsce, gdy system , aplikacja lub usługa w chmurze jest skonfigurowana nieprawidłowo.

jak zapobiegać?

Wysyłać klientom dyrektywy bezpieczeństwa, np. nagłówków bezpieczeństwa.

Zautomatyzowany proces weryfikacji skuteczności konfiguracji i ustawień we wszystkich środowiskach.

A03 Awarie Łańcucha dostaw oprogramowania.

Awarie lub inne zagrożenia w procesie tworzenia, dystrybucji lub aktualizacji oprogramowania. Spowodowane często lukami w zabezpieczeniach lub złośliwymi zmianami w kodzie itp.

Jesteś narażony na ryzyko jeśli nie skanujesz regularnie swojego systemu w poszukiwaniu luk w zabezpieczeniach.

A04 Awarie kryptograficzne

Wszystkie przesyłane dane powinny być szyfrowane na poziomie warstwy transportowej (warstwa 4 modelu OSI) . Oprócz zabezpieczenia warstwy transportowej , ważne jest określenie które dane wymagają dodatkowego szyfrowania w tranzycie. (na poziomie aplikacji, czyli warstwa OSI 7). Aby mieć pewność , że ustawienia i konfiguracje spełniają wymogi bezpieczeństwa zleć ich sprawdzenie specjalistom do spraw bezpieczeństwa.

A05 Wtrysk

Luka umożliwiająca wprowadzenie kodu to wada aplikacji, umożliwia przesłanie niezaufanych danych wejściowych użytkownika do interpretera. (przeglądarki, bazy danych, wiersz poleceń) .Interpreter wykonuje część tych danych wejściowych jako polecenia.

Najlepszym sposobem zapobiegania wstrzyknięciom jest oddzielenie danych od poleceń i zapytań.

A06 Niezabezpieczony projekt

szeroka kategoria luk bezpieczeństwa wynikająca z fundamentalnych błędów w architekturze, logice biznesowej lub braku analizy zagrożeń podczas projektowania, a nie z błędów w kodowaniu. Brak modelowania zagrożeń. - Nieprzewidzenie potencjalnych scenariuszy ataków podczas planowania. Błędy projektowe wymagają zmiany w architekturze systemu, co czyni je trudnymi i kosztownymi w naprawie po zakończeniu produkcji.

A07 Błędy uwierzytelniania

Luki w weryfikacji tożsamości użytkownika i zarządzaniu sesją. Umożliwiają przejęcie kont, kradzież tożsamości oraz dostęp do danych poprzez słabe hasło. Brak uwierzytelniania wieloskładnikowego (MFA). Kategoria ta jest krytyczna, ponieważ prowadzi do przejęcia pełnej kontroli nad kontami użytkownika.

A08 Awarie oprogramowania lub integralności danych

kategoria zagrożeń skupiająca się na kodzie i infrastrukturze, które nie chronią przed naruszeniami integralności. Niezabezpieczone aktualizacje oprogramowania mogą skutkować tym, że atakujący może wstrzyknąć w nie złośliwy kod. (np. brak podpisów cyfrowych.) Dlatego zaleca się używanie podpisów cyfrowych lub podobnych mechanizmów weryfikacji lub sprawdzanie czy oprogramowanie lub dane pochodzą z zaufanego źródła.

A09 Rejestrowanie zabezpieczeń i awarie alertów

Bez rejestrowania i monitorowania ataki i naruszenia nie mogą zostać wykryte. Bez alertów ostrzegawczych bardzo trudno jest szybko i skutecznie zareagować na incydent.

Aplikacja nie może wykrywać aktywnych ataków ani powiadamiać o nich w czasie rzeczywistym. Jeśli dane dziennika nie są poprawnie zakodowane, narażasz się na włamanie lub ataki na systemy rejestrujące.

A10 Niewłaściwe postępowanie w sytuacjach wyjątkowych.

Niewłaściwe zarządzanie sytuacjami wyjątkowymi w oprogramowaniu ma miejsce, gdy programy nie zapobiegają, nie wykrywają i nie reagują na nietypowe sytuacje. Aplikacja nie zapobiega wystąpieniu nietypowej sytuacji, nie identyfikuje sytuacji w momencie jej wystąpienia lub reaguje na nią słabo albo wcale.